ACT01. AUDITORÍA

F1 — Inyección SQL (simulada) en `BuscarPorNombre`

Línea y fichero en el que está ubicado el error:	BaseDatosusuarios.cs, linea 32(construccion de la consulta) y 38-55(motro que la interpreta)
Según los apuntes, ¿que antipatrón es?	No confiar en la entrada //concatenar texto del usuario en una consulta en vez de usar parametros
Si fueras un atacante, ¿cómo lo utilizarías?	metiendo en “nombre a buscar” algo como ‘OR ’
Indica el nivel de gravedad: alto, medio, bajo	ALTA

F2 — Credenciales de prueba impresas en consola

Línea y fichero en el que está ubicado el error:	Program.cs, línea 19 y 72-73 (`CargarUsuariosDeEjemplo`)
Según los apuntes, ¿que antipatrón es?	Clave/contraseña escrita en el código y expuesta al usuario
Si fueras un atacante, ¿cómo lo utilizarías?	cualquiera que ejecute la app ve usuario y contraseña del admin en pantalla; en una build real esas cadenas también quedarían dentro del ejecutable, extraíbles con un descompilador.
Indica el nivel de gravedad: alto, medio, bajo	alta

F3 — Mensaje de error completo mostrado al usuario

Línea y fichero en el que está ubicado el error:	Program.cs linea 60-61 (cath generico en Main)
Según los apuntes, ¿que antipatrón es?	Mostrar el error tecnico completo al usuario en vez de un mensaje generico
Si fueras un atacante, ¿cómo lo utilizarías?	provoncado una excepcion ve ex.ToString() completo claes metodos rutas…

	información que ayuda a mapear la app antes de atarcarla
Indica el nivel de gravedad: alto, medio, bajo	media

F4 — Falta de autorización real en el Panel de administración

Línea y fichero en el que está ubicado el error:	Program-cs linea 44-45 case”5” y 151-159 panelAdministracion
Según los apuntes, ¿que antipatrón es?	mostra el error tecnico
Si fueras un atacante, ¿cómo lo utilizarías?	Confiar en el cliente “ocultar un boton no protege nada” -el rol solo se comprueba para
Indica el nivel de gravedad: alto, medio, bajo	alta

F5 — Falta de validación de entrada al registrar usuario

Línea y fichero en el que está ubicado el error:	program lina 93-102(registrar)
Según los apuntes, ¿que antipatrón es?	no confiar en la entrada no hay lista blanca de longitud formato se acepta cualquier cosa
Si fueras un atacante, ¿cómo lo utilizarías?	registrar nombres vacios kilometricos o con caracteres
Indica el nivel de gravedad: alto, medio, bajo	baja

F6 — Contraseñas con hash MD5 y sin sal

Línea y fichero en el que está ubicado el error:	AuthService.cs, línea 56-61 (CalcularHash)
Según los apuntes, ¿que antipatrón es?	Usar un algoritmo de hash no válido para contraseñas (MD5 está roto y es rápido) y sin sal
Si fueras un atacante, ¿cómo lo utilizarías?	con la lista de hashes filtrada, MD5 se rompe con tablas rainbow o fuerza bruta en poco tiempo; al no haber sal, dos usuarios con la misma contraseña tienen el mismo hash.
Indica el nivel de gravedad: alto, medio, bajo	alta

F7 — Token de sesión generado con `System.Random`

Línea y fichero en el que está ubicado el error:	AuthService.cs, línea 63-67 (GenerarTokenSesion)
Según los apuntes, ¿que antipatrón es?	No usar un generador aleatorio seguro para valores de seguridad
Si fueras un atacante, ¿cómo lo utilizarías?	System.Random no es criptográficamente seguro y el rango (100000-999999) es diminuto; se puede predecir o fuerza-bruta-ear un token válido y suplantar a otro usuario.
Indica el nivel de gravedad: alto, medio, bajo	alta

F8 — Log con datos sensibles (token de sesión)

Línea y fichero en el que está ubicado el error:	AuthService.cs, línea 49
Según los apuntes, ¿que antipatrón es?	Registrar contraseñas/tokens en los logs
Si fueras un atacante, ¿cómo lo utilizarías?	cualquiera con acceso a la consola/logs ve el token de sesión en claro y lo puede reutilizar para suplantar a ese usuario.
Indica el nivel de gravedad: alto, medio, bajo	media

F9 — Sesión guardada en disco sin cifrar

Línea y fichero en el que está ubicado el error:	AuthService.cs, línea 69-72 (GuardarSesionEnDisco)
Según los apuntes, ¿que antipatrón es?	Confiar en los datos guardados en el dispositivo sin protegerlos
Si fueras un atacante, ¿cómo lo utilizarías?	sesion.txt queda en texto plano con usuario:token; con acceso al dispositivo se puede leer o modificar para suplantar la sesión.
Indica el nivel de gravedad: alto, medio, bajo	media

F10 — Sin límite de intentos de login (fuerza bruta)

Línea y fichero en el que está ubicado el error:	AuthService.cs, línea 33-54 (IniciarSesion)
Según los apuntes, ¿que antipatrón es?	Falta de defensa en profundidad — no hay bloqueo tras intentos fallidos
Si fueras un atacante, ¿cómo lo utilizarías?	probar contraseñas de forma automática contra un usuario conocido sin ningún freno.
Indica el nivel de gravedad: alto, medio, bajo	media

F11 — Clave de API escrita en el código

Línea y fichero en el que está ubicado el error:	RedService.cs, línea 9
Según los apuntes, ¿que antipatrón es?	Secreto escrito en el código fuente
Si fueras un atacante, ¿cómo lo utilizarías?	descompilando el ejecutable se extrae la API key en segundos y se usa para llamar al servidor en nombre de la app.
Indica el nivel de gravedad: alto, medio, bajo	alta

F12 — Comunicación por HTTP en vez de HTTPS

Línea y fichero en el que está ubicado el error:	RedService.cs, línea 10 y 27-28
Según los apuntes, ¿que antipatrón es?	Comunicaciones sin cifrar
Si fueras un atacante, ¿cómo lo utilizarías?	con un ataque man-in-the-middle en la misma red, se lee o modifica el tráfico (incluida la api_key), todo en texto plano.
Indica el nivel de gravedad: alto, medio, bajo	alta

F13 — API key y datos como parámetros en la URL

Línea y fichero en el que está ubicado el error:	RedService.cs, línea 28
Según los apuntes, ¿que antipatrón es?	Enviar secretos en la URL en vez de en una cabecera
Si fueras un atacante, ¿cómo lo utilizarías?	esas URLs quedan registradas en logs de servidor, proxies e historial; con acceso a cualquiera de esos registros se obtiene la clave.
Indica el nivel de gravedad: alto, medio, bajo	Media